KALI LINUX

Reconnaissance, Scanning & Analysis

Expanded command sheet • scan types, examples, output interpretation, and safe lab workflow

Included: WHOIS, nslookup, Nmap, Armitage, theHarvester, Netdiscover, Sublist3r, Wireshark, FOCA, Google search operators, Maltego, Shodan, Nessus, Nikto, Robtex, and Sysmon.

Authorization: Run active scans only against systems you own or have explicit permission to test. Use localhost, reserved example domains, or an intentionally vulnerable lab VM. Replace placeholders with your approved lab values.

Credential safety: The uploaded sheet contained a Maltego username/password. It is intentionally omitted here. Never share real passwords/API keys in a PDF; rotate any credential that was exposed.

Placeholders used in examples

```
TARGET=192.168.56.101        # authorized lab VM
LAB_SUBNET=192.168.56.0/24    # isolated lab network
DOMAIN=example.com            # reserved documentation domain
```

Setup and workflow

```
sudo apt update
sudo apt install -y whois dnsutils nmap netdiscover wireshark tshark theharvester sublist3r nikto
ip -br addr
ip route
ip neigh
ss -tulpn
```

• Confirm scope, permitted targets, ports, timing, and scan window first.

• Start with passive collection, then limited discovery, then targeted scans.

• Save exact commands, timestamps, tool versions, and sanitized output.

• Treat scanner findings as leads; validate before reporting.

• FOCA is primarily Windows software; Sysmon is for Windows endpoints. Maltego, Shodan, Nessus, Robtex, and Armitage may need separate setup/accounts.

1. WHOIS — registration and allocation lookups

WHOIS retrieves public domain-registration or IP allocation records; it is not a port scanner.

Domain lookup

```
whois example.com
```

Review registrar/registry, domain status, nameservers, and dates where published.

IP allocation lookup

```
whois 8.8.8.8
```

May identify an allocation or organization, not necessarily the operator of a particular service.

Save output

```
whois example.com | tee whois-example.txt
```

Writes output to the terminal and a text file.

Help

```
whois --help
```

Check options supported by your installed package.

Interpretation / caution: Privacy protection and registry policy may hide fields. Records can be stale; confirm important details elsewhere.

2. nslookup — DNS query types

Use nslookup to ask a DNS resolver for address, mail, name-server, text, and reverse records.

Default lookup

```
nslookup example.com
```

Returns default address information (commonly A/AAAA).

Specific resolver

```
nslookup example.com 1.1.1.1
```

Compares results from a named resolver.

A / IPv4

```
nslookup -type=A example.com
```

Returns IPv4 records if present.

AAAA / IPv6

```
nslookup -type=AAAA example.com
```

Returns IPv6 records if present.

MX / mail servers

```
nslookup -type=MX example.com
```

Lists mail exchangers and preference values.

NS / name servers

```
nslookup -type=NS example.com
```

Lists name servers returned by the resolver.

TXT

```
nslookup -type=TXT example.com
```

May include SPF or verification strings.

SOA

```
nslookup -type=SOA example.com
```

Returns zone authority metadata if published.

Reverse / PTR

```
nslookup 8.8.8.8
```

Attempts a reverse lookup; not every IP has a PTR record.

Interactive

```
nslookup
> set type=MX
> example.com
> exit
```

Useful for checking multiple record types in one session.

Interpretation / caution: NXDOMAIN means the name was not found by that resolver; timeout may mean network/resolver trouble. Different resolvers may have different cached or split-DNS answers.

3. Nmap — host discovery and TCP/UDP scans

Begin with the smallest scan that answers the question. Replace TARGET with a host in your approved lab.

Host discovery only

```
nmap -sn 192.168.56.0/24
```

Finds hosts that respond to discovery probes without a normal port scan.

Basic common-port scan

```
nmap TARGET
```

Scans Nmap's default set of common TCP ports.

TCP SYN scan

```
sudo nmap -sS TARGET
```

Half-open SYN scan; usually needs raw-packet privileges.

TCP connect scan

```
nmap -sT TARGET
```

Uses the operating system's connect() call.

Selected ports

```
nmap -p 22,80,443 TARGET
```

Scans only listed TCP ports.

Limited port range

```
nmap -p 1-1000 TARGET
```

Checks ports 1–1000.

All TCP ports

```
nmap -p- TARGET
```

Checks TCP ports 1–65535; can take longer.

Service/version detection

```
nmap -sV TARGET
```

Probes open ports to infer services and versions.

OS fingerprinting

```
sudo nmap -O TARGET
```

Attempts OS detection; results are estimates.

Default NSE scripts

```
nmap -sC TARGET
```

Runs the default script set; review behavior and scope.

Combined detection

```
sudo nmap -sC -sV -O TARGET
```

More probing; better after an initial scan.

Selected UDP ports

```
sudo nmap -sU -p 53,123,161 TARGET
```

Checks chosen UDP ports; often slower and ambiguous.

Top 20 UDP ports

```
sudo nmap -sU --top-ports 20 TARGET
```

Smaller UDP sample for a lab.

Traceroute

```
nmap --traceroute TARGET
```

Attempts to identify network hops.

Timing template

```
nmap -T3 TARGET
```

Moderate timing; aggressive timing can increase load/loss.

Save normal output

```
nmap -sV -oN scan.txt TARGET
```

Writes human-readable output.

Save multiple formats

```
nmap -sV -oA lab-scan TARGET
```

Writes normal, XML, and grepable output.

Interpretation / caution: Port states: open = a listener appears reachable; closed = host responds but no listener; filtered = filtering/no clear response; open|filtered = Nmap cannot distinguish. A port number alone does not prove the service identity.

Nmap scan types at a glance

Type	Example	Meaning
-sn	nmap -sn LAB_SUBNET	Host discovery; no normal port scan.
-sS	sudo nmap -sS TARGET	TCP SYN scan; raw-packet privilege typically required.
-sT	nmap -sT TARGET	TCP connect scan.
-sU	sudo nmap -sU -p 53,123 TARGET	UDP; often slower/ambiguous.
-sV	nmap -sV TARGET	Service/version probing.
-O	sudo nmap -O TARGET	OS fingerprint estimate.
-sC	nmap -sC TARGET	Default NSE scripts.
-p-	nmap -p- TARGET	All TCP ports.

Syntax correction: `-p-` means all TCP ports; do not combine it with a comma-separated port list. Use `-p 22,80,443` for selected ports or `-p-` alone for all TCP ports.

4. Netdiscover — local ARP discovery

Netdiscover identifies devices on a directly connected local IPv4 segment using ARP; it is not an Internet-wide scanner.

Check interface/subnet

```
ip -br addr
ip route
```

Identify the interface and local subnet first.

Passive mode

```
sudo netdiscover -p -i eth0
```

Listens for ARP traffic without actively probing; interface may differ.

Active lab subnet

```
sudo netdiscover -i eth0 -r 192.168.56.0/24
```

Actively probes the specified lab subnet.

Check options

```
netdiscover -h
```

Confirm flags for your installed version.

Interpretation / caution: Output can show IP, MAC, and a vendor guess. Virtual machines and randomized MACs can make vendor identification unreliable.

5. theHarvester — public OSINT

Collects publicly indexed domain-related data through supported sources; source availability and API requirements change.

Help / sources

```
theHarvester -h
```

See sources and flags supported by your installed version.

Basic query

```
theHarvester -d example.com -b duckduckgo
```

Requests public results associated with the domain where that source is supported.

Limit results

```
theHarvester -d example.com -b duckduckgo -l 100
```

Limits requested results in versions supporting `-l`.

Alternative source

```
theHarvester -d example.com -b bing
```

Use a source shown by local help; it may require a key.

Save output

```
theHarvester -d example.com -b duckduckgo -f example-results
```

Output options vary; verify `-f` syntax locally.

Interpretation / caution: Potential output includes hostnames and emails. Duplicates, stale records, and false associations are common; a discovered hostname is not automatically in scan scope.

6. Sublist3r — subdomain enumeration

Attempts to discover subdomains through public search sources; upstream source changes can make results incomplete.

Basic enumeration

```
sublist3r -d example.com
```

Enumerates subdomains of the chosen domain.

Save results

```
sublist3r -d example.com -o subdomains.txt
```

Writes names to a text file.

Thread count

```
sublist3r -d example.com -t 10
```

Sets thread count in versions supporting `-t`; higher is not always better.

Verbose mode

```
sublist3r -d example.com -v
```

Shows additional progress in versions supporting `-v`.

Help

```
sublist3r -h
```

Check version-specific flags and dependency errors.

Interpretation / caution: Validate results. Hostnames may be retired, parked, or hosted on shared infrastructure. Do not automatically scan every result without scope approval.

7. Wireshark / TShark — packet capture

Capture only traffic you are authorized to inspect. Practice with your own lab traffic; capturing others' traffic may violate privacy and policy.

Launch GUI

```
wireshark
```

Choose the correct interface and begin capture.

List interfaces

```
tshark -D
```

Lists available capture interfaces.

Live capture

```
sudo tshark -i eth0
```

Displays packets in terminal; stop with Ctrl+C.

Save capture

```
sudo tshark -i eth0 -w lab-capture.pcapng
```

Saves packets for later review.

Read a capture

```
tshark -r lab-capture.pcapng
```

Analyzes an existing file.

Capture filter: DNS

```
sudo tshark -i eth0 -f 'udp port 53'
```

Capture filter reduces packets as they are recorded.

Display filter: DNS

```
tshark -r lab-capture.pcapng -Y dns
```

Display filter applies after capture.

HTTP requests

```
tshark -r lab-capture.pcapng -Y 'http.request'
```

Only works where traffic is plain HTTP and dissected.

Initial TCP SYNs

```
tshark -r lab-capture.pcapng -Y 'tcp.flags.syn == 1 && tcp.flags.ack == 0'
```

Shows SYN packets without ACK.

One endpoint

```
tshark -r lab-capture.pcapng -Y 'ip.addr == 192.168.56.101'
```

Matches the IP as source or destination.

Interpretation / caution: Capture filter `-f` uses libpcap syntax; display filter `-Y` uses Wireshark syntax. HTTPS payloads are encrypted without an authorized decryption setup, though metadata may remain visible.

8. Armitage — Metasploit GUI (lab only)

Armitage is a legacy GUI front end to Metasploit on many systems. Use only intentionally vulnerable VMs on an isolated lab network.

Check installation

```
command -v armitage
armitage --help
```

The program may not be packaged or compatible with your Kali release.

Launch GUI

```
sudo armitage
```

May require a running Metasploit database/service.

Open console

```
msfconsole -q
```

Opens Metasploit console for authorized lab work.

Search scanner modules (inside console)

```
search type:auxiliary name:scanner
```

Lists matching modules; inspect their descriptions before use.

Inspect a module (inside console)

```
info auxiliary/scanner/portscan/tcp
```

Shows module options and behavior; names can vary by version.

Interpretation / caution: Before running a module, verify RHOSTS targets only your lab VM and understand the effect. Do not run exploit modules against public IPs or real organizations.

9. FOCA — document metadata

FOCA is primarily a Windows GUI application for finding and extracting metadata from documents. It is not a standard Kali CLI scanner.

Typical workflow

```
1. Create/open a project.
2. Use an authorized domain or sample documents.
3. Choose document types and sources.
4. Download only permitted public files.
5. Extract metadata and export findings.
```

UI labels vary by version.

Safe local practice

```
Create a test DOCX/PDF with synthetic author/path metadata and analyze it.
```

Use your own files and remove personal metadata before publishing.

Interpretation / caution: Metadata may reveal authors, usernames, software, or file paths. Findings are contextual clues, not proof of a vulnerability.

10. Google search operators — passive discovery

Use search operators to find material indexed publicly. They do not grant permission to access restricted systems.

Domain only

```
site:example.com
```

Limits results to a domain.

PDF files

```
site:example.com filetype:pdf
```

Finds indexed PDFs.

Title phrase

```
site:example.com intitle:"security policy"
```

Looks for a phrase in page titles.

URL term

```
site:example.com inurl:docs
```

Finds URLs containing a term.

Page text

```
site:example.com intext:contact
```

Searches indexed page text.

Exclude section

```
site:example.com -inurl:blog
```

Excludes matching URLs.

Multiple file types

```
site:example.com (filetype:pdf OR filetype:pptx)
```

Operator behavior varies; simplify if needed.

Interpretation / caution: The old `cache:` operator is deprecated and should not be relied on. Do not bypass login controls or access files outside your authorization.

11. Maltego — relationship graphing

Maltego graphs relationships among domains, DNS names, IPs, organizations, and other entities. Transforms depend on edition, account, and data sources.

Create a graph

```
Create graph → add a Domain entity such as example.com
```

Use a domain you own or an instructor-provided training domain.

DNS transforms

```
Right-click Domain → Run Transform → select a DNS/name-server transform
```

Exact transform names vary by installed transform packs.

Explore infrastructure

```
Add a discovered DNS Name/IP entity and run a relevant transform
```

Stay within scope; graph edges may be inferred or stale.

Save/export

```
Save the graph and export a sanitized screenshot/report
```

Redact private email addresses, credentials, tokens, and unrelated personal data.

Interpretation / caution: Never put real account passwords in a worksheet. Use approved secrets storage or the app's credential manager.

12. Shodan — indexed exposed services

Shodan indexes service banners from internet-connected devices. Results may be old or incomplete and do not prove a vulnerability.

Open Shodan

```
Visit https://www.shodan.io
```

Account and query limits depend on plan.

Search an IP

```
host:8.8.8.8
```

Example lookup of indexed observations for a public IP.

Search a port

```
port:443
```

Broad query for services indexed on TCP/UDP port 443 as understood by Shodan.

Check your own asset

```
Search the public IP of an asset you own, if policy permits
```

Confirm ownership and scope first.

Interpretation / caution: Review last-seen dates, banners, ports, and attribution. Never attempt login or exploitation based only on a Shodan result.

13. Nessus — vulnerability assessment

Nessus runs configured vulnerability checks. Use a lab VM or explicitly approved scope; some scan policies create significant traffic.

Create scan

```
Nessus → My Scans → New Scan
```

Choose the instructor-approved template.

Set target

```
Targets: 192.168.56.101
```

Replace with the IP of your authorized lab VM.

Choose policy

```
Basic Network Scan or the template specified by your instructor
```

Credentialed checks may be more complete but require secure, authorized credentials.

Run/monitor

```
Start scan and monitor status
```

Stop if the target becomes unstable or scope is wrong.

Review findings

```
Open each finding; inspect severity, evidence, affected port, plugin output, remediation
```

Validate false positives and assess actual impact.

Export report

```
Export only an approved report format
```

Store reports securely; they may contain sensitive infrastructure details.

Interpretation / caution: Severity alone is not a full risk assessment. Consider exposure, exploitability, business impact, and compensating controls.

14. Nikto — web server checks

Nikto checks web servers for known risky files, outdated-software clues, and configuration issues. It can generate many requests.

Local test web app

```
nikto -h http://127.0.0.1:8000
```

Use if your own test app is listening on port 8000.

Lab web server

```
nikto -h http://192.168.56.101
```

Replace with your lab VM address.

Specific port

```
nikto -h 192.168.56.101 -p 8080
```

Use only if that port hosts a web server.

HTTPS lab server

```
nikto -h https://192.168.56.101
```

Use when HTTPS is enabled in your lab.

Save report

```
nikto -h http://192.168.56.101 -output nikto-report.txt
```

Writes results to a file.

Help

```
nikto -Help
```

Check exact options in your installed version.

Interpretation / caution: Validate each reported path/version. A finding can be a false positive or intentionally exposed resource. Do not scan third-party sites without written authorization.

15. Robtex — public DNS/IP relationships

Robtex is a web-based lookup service, not a Kali terminal command.

Open site

```
Visit https://www.robtex.com
```

Use the current site search.

Domain lookup

```
Search for example.com
```

Review public DNS and related IP/name observations.

IP lookup

```
Search an IP associated with your own asset
```

Shared hosting and CDNs can produce misleading associations.

Interpretation / caution: Cross-check important details with authoritative DNS and your asset inventory; results may be cached or incomplete.

16. Sysmon — Windows endpoint telemetry

Sysmon is a Windows monitoring service, not a Kali scanner. Install/configure only on a Windows system you administer.

Check service (PowerShell)

```
Get-Service Sysmon*
```

Shows whether Sysmon is installed/running.

View events

```
Event Viewer → Applications and Services Logs → Microsoft → Windows → Sysmon → Operational
```

Inspect events enabled by the current configuration.

Install with config (elevated CMD)

```
Sysmon64.exe -accepteula -i sysmon-config.xml
```

Installs Sysmon with the supplied configuration file.

Update config

```
Sysmon64.exe -c sysmon-config.xml
```

Applies a new configuration.

Show current config

```
Sysmon64.exe -c
```

Prints active configuration in supported versions.

Uninstall

```
Sysmon64.exe -u
```

Only when approved by endpoint policy.

Interpretation / caution: Use a trusted, reviewed config and Microsoft's current schema. Poor filtering can miss useful events or generate excessive logs.

17. Result interpretation & lab reporting

Nmap state quick reference

State	Meaning	Follow-up
open	A listener appears reachable.	Confirm service identity and whether it is expected.
closed	Host responds but no listener is present.	Check whether service should exist.
filtered	Filtering/no response prevents a clear result.	Review firewall/ACL and scan vantage point.
open|filtered	Nmap cannot distinguish open from filtered (common with UDP).	Use protocol-aware checks and host logs.
host seems down	Discovery probes got no response.	Check IP, route, lab network mode, and firewall.

Record these details for every exercise

• Date/time and timezone; operator; tool version.

• Exact target and reason it is in scope.

• Exact command/UI settings, ports, scripts, timing, and output filename.

• Evidence line/screenshot plus interpretation confidence: confirmed, likely, or unverified.

• False-positive checks, limitations, and recommended remediation.

• Remove passwords, API keys, private personal data, and sensitive details before sharing.

Sample lab report entry

Objective: Identify exposed TCP services on an instructor-provided VM.

```
nmap -sV -p 22,80,443 -oN lab-services.txt 192.168.56.101
```

Observation: Record port states and service/version strings actually shown in output.

Inference: An open port indicates a reachable listener; it does not alone prove a vulnerability.

Follow-up: Confirm the service is expected, check vendor advisories, and validate within the approved test plan.

Common troubleshooting

• `command not found`: check spelling with `command -v TOOL`; verify package availability for your Kali version.

• `permission denied`: elevate only when required and authorized; do not reflexively run every tool as root.

• `could not resolve`: test DNS with nslookup and check resolver/connectivity.

• No OSINT results: sources may block requests, require keys, or have changed; no result does not mean no asset exists.

• UDP `open|filtered`: ambiguous; corroborate with protocol-specific tests or host-side logs.

This is an educational reference, not a substitute for tool documentation, organizational policy, or written authorization. Tool options change; check local help (`-h`, `--help`) or the tool's current documentation.